

CURSO

PROCESSO DE GESTÃO DE RISCOS DE PRIVACIDADE

Módulo III

Diretrizes e práticas para identificar, avaliar, tratar, monitorar e comunicar riscos de privacidade na ANAC.



PROTEGER
INFORMAÇÕES



PRESERVAR A
PRIVACIDADE



GARANTIR
CONFORMIDADE



FORTALECER A
GOVERNANÇA



Conteúdo

Módulo III:

1. TRATAMENTO DE RISCOS
 - a. Opções de tratamento
 - b. Diretrizes para o tratamento de riscos
 - c. Etapas do tratamento
 - i. Estimar Recursos Para o Tratamento dos Riscos
 - ii. Definir Resposta aos Riscos
 - iii. Implementar Resposta aos Riscos
2. COMUNICAÇÃO DOS RISCOS
3. MONITORAMENTO DOS RISCOS
 - a. Monitorar a Gestão de Riscos de Privacidade
 - b. Monitorar e revisar o Tratamento de Riscos
4. CONCLUSÃO FINAL
5. REFERÊNCIAS BIBLIOGRÁFICAS

Ao final deste Módulo, esperamos que você seja capaz de:

- I – Identificar as opções de tratamentos dos riscos identificados, registrando suas etapas no Plano de Tratamento de Riscos – PTR;
- II – Implementar as respectivas respostas elencadas no PTR;
- III – Comunicar, às unidades competentes, em um processo contínuo, o andamento das atividades de GRPSI, promovendo diálogo constante;
- IV – Monitorar constantemente o processo de GRPSI, verificando se existem procedimentos ou novas informações que possam impactar os resultados da Análise de Riscos



1. TRATAMENTO DE RISCOS

Nesta etapa do processo todas as análises realizadas e informações obtidas anteriormente serão utilizadas na tomada de decisão sobre como a organização agirá em relação aos riscos relacionados ao tratamento de dados pessoais.



Opções de tratamento

O tratamento de riscos envolve uma ou mais opções de tratamento, como descritas a seguir:

1. **Mitigar os riscos.** O nível de risco deve ser reduzido pela implementação de controles de modo que o risco residual possa ser reavaliado como sendo aceitável. A imagem abaixo demonstra que, em geral, estes controles devem fornecer pelo menos um dos seguintes tipos de proteção:



2. **Aceitar os riscos:** Trata-se da decisão de reter o risco sem maiores ações. Se o nível dos riscos satisfaz o critério de aceitação, não existe necessidade de implementar controles adicionais, contudo, a decisão deve ser registrada e justificada no Mapa de Riscos.
3. **Transferir os riscos:** Transferência do risco para outra parte externa, como a contratação de um seguro, que irá apoiar em relação às consequências do risco, ou por subcontratação de serviços, onde uma parte externa (empresa contratada) assumirá a responsabilidade pela execução de uma atividade ou pela gestão de um ativo que possui riscos associados.
4. **Evitar riscos:** Para riscos considerados muito altos, ou se os custos de implementação de outro tratamento de risco excedem os benefícios, a decisão deve ser eliminar o risco por completo, por exemplo, pela retirada de forma planejada de atividades existentes

Diretrizes para o tratamento de riscos

Conforme descrito na imagem abaixo, o tratamento de riscos segue algumas diretrizes:



Etapas do tratamento

- I. Estimar Recursos Para o Tratamento dos Riscos
- II. Definir Resposta aos Riscos
- III. Implementar Resposta aos Riscos

I. Estimar Recursos Para o Tratamento dos Riscos



Deve ser feita uma estimativa do custo, esforço e de prazo para implementar os controles identificado nas situações "Não implementado".

O responsável pela unidade da organização deve, com apoio dos responsáveis por ativos e do próprio gestor de riscos, estimar, no Mapa de Riscos, os custos de implementação dos controles para tratar cada risco, o quanto de esforço é necessário para implementar cada controle definido anteriormente, bem como identificar se existe alguma restrição que impacte na escolha do tratamento do risco.

Em especial, deve ser avaliada a disponibilidade de recursos humanos para realizar os tratamentos de riscos analisados.

II. Definir Resposta aos Riscos

O gestor de riscos deve analisar cada risco no Mapa de Riscos e identificar o nível do risco e o tratamento recomendado para este nível.

A imagem abaixo, ressalta as opções de tratamento de riscos, salientando que uma das 4 opções acima deve ser selecionada como resposta ao tratamento de riscos e normalmente a primeira opção é a mais utilizada.



Além da justificativa para a opção de tratamento adotada, o gestor de riscos deve analisar o status de implementação dos controles (não implementado; implementado; não se aplica), bem como as estimativas (custo, esforço, tempo e restrições) para a efetiva instalação dos mesmos.

O gestor de riscos também deve definir, para cada risco, um ou mais controles a serem implementados no Mapa de Riscos, bem como sua respectiva periodicidade de monitoramento.

III. Implementar Resposta aos Riscos

O gestor de riscos deve, para cada risco a ser tratado, associar um **Plano de Tratamento de Riscos – PTR**, que usualmente abordará mais de um risco.

Deve ser definido e comunicado um responsável pela elaboração de cada PTR, que normalmente é o responsável pela unidade organizacional, que deverá levantar informações sobre os riscos relacionados ao tratamento de dados pessoais a ser tratado, incluindo as medidas de proteção da privacidade.



Este levantamento constará do PTR e deverá conter:

- Ativos envolvidos;
- Ameaças identificadas;
- Opções de tratamento;
- Controles a serem implementados;
- Estimativas e restrições;
- Detalhamento das ações a serem adotadas.

O **Plano de Tratamento de Riscos** também deverá oficializar os responsáveis por executar cada tratamento, cuja execução se iniciará somente após a avaliação e validação pelo gestor de riscos e pela autoridade competente.

2. COMUNICAÇÃO DOS RISCOS



A etapa de Comunicação consiste em um processo contínuo e iterativo para fornecer, compartilhar ou obter informações e promover o diálogo com as partes interessadas no processo de Gerenciar Riscos de Privacidade e Segurança da Informação (GRPSI).

Tem por objetivo comunicar o desenvolvimento das atividades e os resultados alcançados em todas as fases da gestão de riscos.

Este processo deve ser iniciado em paralelo com a etapa “Estabelecer Contexto”, desenvolvendo-se simultaneamente com os demais processos durante todo o processo de gestão de riscos.

Os riscos classificados como de nível alto deverão ser formalizados ao CSIP, que poderá deliberar sobre medidas estratégicas relacionadas à proteção de dados pessoais.

O gestor de segurança da informação e o encarregado pelo tratamento de dados pessoais, após a aprovação dos relatórios de identificação, análise e avaliação dos riscos de segurança da informação e de privacidade, no âmbito de suas respectivas competências, deverão encaminhá-los conjuntamente à alta administração.

3. MONITORAMENTO DOS RISCOS

Essa etapa tem por objetivo monitorar os resultados do Processo de GRPSI. Novas ameaças, novas vulnerabilidades e novos ativos podem alterar ou ampliar os riscos anteriormente avaliados, tornando necessário o monitoramento.

O monitoramento se desenvolve simultaneamente com os demais processos, assegurando que as medidas de resposta aos riscos planejadas sejam adequadamente implementadas.



Compõem este processo as seguintes atividades:

- I. Monitorar a gestão de riscos de privacidade
- II. Monitorar o tratamento de riscos

I. Monitorar a Gestão de Riscos de Privacidade

Os responsáveis por ativos, os responsáveis pelas unidades da organização, o gestor de riscos e a autoridade competente devem verificar, a qualquer momento do processo de GRPSI, se existem procedimentos ou novas informações que possam impactar ou alterar os resultados da Análise de Riscos de modo geral, tais como:

- Novos ativos, substituídos ou descartados;
- Restrições ou escopo que foram modificados;
- Alterações na valoração dos ativos;
- Novas ameaças e vulnerabilidades;
- Incidentes de segurança ou incidentes envolvendo dados pessoais que possam ocorrer após a análise de riscos; e
- Alterações relevantes nas atividades de tratamento de dados pessoais, tais como novas finalidades, novos compartilhamentos ou mudanças no volume de dados tratados.

O gestor de riscos deve notificar os responsáveis pela realização de processos, atividades ou tarefas, fornecendo o prazo e as informações necessárias para que se procedam as atualizações

II. Monitorar e revisar o Tratamento de Riscos

Cada responsável por um Plano de Tratamento de Riscos (PTR) deve avaliar periodicamente a sua execução e registrar o progresso da implementação (em percentual realizado).

Ao final da implementação do PTR, o responsável deve avaliar a correção dos controles estabelecidos por meio de verificações e deve fornecer uma descrição sobre as ações realizadas.



Além disso, o responsável deve anexar uma evidência da correta implementação dos controles previstos no PTR e comunicar ao gestor de riscos o final da implementação do PTR.

O gestor de riscos deve obter as informações constantes de cada PTR, para verificar o status de cada atividade, do ponto de vista do cumprimento dos prazos, dos testes e da efetividade dos controles implementados.

Ao ser comunicado do final da implementação de um PTR, o gestor de riscos deve avaliar as evidências fornecidas, verificando a efetividade dos controles implementados e atualizar o estado de implementação nos Planos de Tratamento de Riscos.

Aprovado o tratamento, gestor de riscos deve comunicar o gestor de segurança da informação e o encarregado pelo tratamento de dados pessoais dos resultados do tratamento de riscos, para decidir se o tratamento de riscos realizado é suficiente ou se outras ações são necessárias.

Neste ponto de decisão, atividades de processos anteriores podem ser reexecutadas se o julgamento indicar a necessidade de realizar outras ações para tratar os riscos. Nesses casos, o gestor de riscos deve ser informado da necessidade de revisar decisões e devem ser fornecidas descrições das questões identificadas pela organização.

Em resumo, o gestor de riscos deve monitorar todos os riscos que compõem o Mapa de Riscos. Isso inclui, no caso de riscos aceitos (retidos), avaliar periodicamente se há alterações relevantes que justifiquem a definição de outro tratamento.

O relatório de identificação, análise e avaliação dos riscos de privacidade deverá ser atualizado anualmente e sempre que houver alteração em algum dos fatores de risco ou em algum contexto interno ou externo, este fato deverá enviado ao gestor de segurança da informação e ao encarregado pelo tratamento de dados pessoais, no âmbito de suas respectivas competências, para aprovação.

Ressalta-se ainda que casos omissos serão resolvidos pelo encarregado pelo tratamento de dados pessoais, no âmbito de suas competências, podendo o tema ser submetido ao CSIP quando necessário

4. ESTUDO DE CASO – CONCLUSÃO

Cenário hipotético - Continuação

Nos módulos anteriores, o **Gestor de Riscos** estabeleceu o contexto e o escopo (Módulo de Acesso Externo do SACI).

A análise técnica identificou a ameaça de "Acesso não autorizado a sistemas de TI", potencializada pela vulnerabilidade de "Configurações inseguras" (autenticação simples e falta de criptografia).



O nível de risco foi classificado como "**Alto**", exigindo uma resposta imediata conforme as diretrizes da ANAC. Com o diagnóstico em mãos, o Gestor de Riscos deve agora conduzir o tratamento.

1. Definição da Resposta aos Riscos

Após avaliar as opções de tratamento (Aceitar, Evitar, Transferir ou Mitigar), a organização decidiu por **mitigar os riscos**.

- **Justificativa:** A opção de "Aceitar" foi descartada por não ser compatível com o apetite de risco institucional para dados sensíveis de saúde, e "Transferir" (contratação de seguro) não resolveria a vulnerabilidade técnica crítica que coloca em xeque a conformidade com a LGPD.

2. Estimativa de Recursos e Elaboração do PTR (Anexo IV)

O Responsável pela Unidade Organizacional, com suporte técnico do Responsável por Ativos (TI), elaborou o Plano de Tratamento de Riscos (PTR). Foram Estimados os seguintes elementos:

- **Esforço e Recursos:** Mobilização da equipe de desenvolvimento para integrar o SACI ao novo módulo de MFA (Múltiplo Fator de Autenticação) a ser desenvolvido.
- **Controles a implementar (PTR):** Planejou-se a ativação imediata dos controles identificados no Módulo 2 como "não implementados": Autenticação segura (A.3.23), Criptografia (A.3.26) e o aprimoramento dos Logs com alertas de exfiltração (A.3.25).
- **Prazos:** Estabeleceu-se o cronograma emergencial de 30 dias para a conclusão das medidas de mitigação.

O anexo VI apresenta o Plano de Tratamento de Riscos (PTR) preenchido com os dados referentes ao cenário hipotético estabelecido neste Estudo de Caso.

3. Comunicação dos Riscos e Validação

Como o risco foi classificado como de nível **Alto**, o Gestor de Riscos formalizou o cenário ao **CSIP** (Comitê de Segurança da Informação e de Proteção de Dados Pessoais).

- O Encarregado (DPO) analisou o PTR e, juntamente com o Gestor de Segurança da Informação, encaminhou o relatório à alta administração para garantir o apoio institucional e a prioridade na alocação de pessoal técnico.

4. Monitoramento e Revisão do Tratamento

Para garantir que os riscos residuais permaneçam em níveis aceitáveis, o gestor estabeleceu o seguinte plano de monitoramento:

- **Verificação de Eficácia:** Ao final da implementação do PTR, o responsável pela TI fornecerá evidências de testes para validar a robustez do novo MFA.
- **Ciclo de Atualização:** O Relatório de Identificação, Análise e Avaliação (mapa de riscos) deste sistema será revisado anualmente, ou imediatamente caso ocorram novos incidentes ou mudanças significativas na arquitetura do SACI.

5. Conclusão do Estudo de Caso

A aplicação do rito do processo de Gestão de Riscos de Privacidade e Segurança da Informação (GRPSI) no SACI (módulo de “Regulados) demonstrou que a segurança não é um estado estático, mas um processo contínuo de governança.

Através do Estabelecimento do Contexto, a ANAC delimitou onde o esforço era mais necessário; com a Identificação e Análise dos riscos, transformou uma percepção de insegurança em dados técnicos (Risco Alto); e, finalmente, com o Tratamento e Monitoramento, implementou controles baseados em normas internacionais (ISO 27701) para proteger o direito fundamental à privacidade dos titulares.

5. CONCLUSÃO FINAL

Ao longo deste curso, vimos que a **Gestão de Riscos de Privacidade e Segurança da Informação (GRPSI)** deixou de ser uma tarefa meramente técnica para se tornar um requisito estratégico de sustentabilidade institucional.

Fundamentado na LGPD e nas normas ABNT NBR ISO/IEC 27005 e 27701, o processo garante que a proteção dos direitos fundamentais dos titulares seja integrada ao dia a dia da Agência de forma auditável e transparente.

Exploramos como o estabelecimento do contexto, a identificação rigorosa de ativos e a análise baseada nos quatro atributos de impacto (VT, SD, DL e TI) permitem transformar incertezas em decisões gerenciais precisas para o preenchimento do **Mapa de Riscos**.

O estudo de caso do Sistema SACI demonstrou, na prática, que identificar vulnerabilidades e planejar a mitigação por meio do Plano de Tratamento de Riscos (PTR) é o que **diferencia uma organização reativa de uma instituição preditiva e resiliente**.

O sucesso deste sistema de gestão depende da atuação coordenada de todos os atores, desde o Encarregado (DPO) e o CSIP até os Responsáveis por Ativos em cada unidade organizacional.

O monitoramento contínuo e a atualização anual das análises asseguram que a ANAC **permaneça protegida contra ameaças modernas**, preservando a confiança da sociedade e a continuidade dos processos regulatórios da aviação civil brasileira

6. REFERÊNCIAS BIBLIOGRÁFICAS

1. AGÊNCIA NACIONAL DE AVIAÇÃO CIVIL. **Processo de gestão de privacidade segurança da informação**. Brasília: ANAC, 2026. 29 p.
2. ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **Segurança da informação, segurança cibernética e proteção à privacidade**: controles de segurança da informação = Information security, cybersecurity and privacy protection: information security controls. 3. ed. Rio de Janeiro, 2022. (ABNT NBR ISO/IEC 27002:2022)
3. ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **Segurança da informação, segurança cibernética e proteção da privacidade**: sistemas de gestão da privacidade da informação: requisitos e orientações = Information security, cybersecurity and privacy protection : privacy information management systems : requirements and guidance. 2. ed. Rio de Janeiro, 2026. (ABNT NBR ISO/IEC 27701:2026)